UNIVERSIDAD DE LAS FUERZAS ARMADAS – ESPE

Departamento de Ciencias de la Computación



Ingeniería de Software

INGENIERÍA DE SOFTWARE

PROYECTO INTEGRADOR DEL PRIMER PARCIAL

Autenticación JWT/RBAC y detección de esteganografía

2026

Asignatura	Desarrollo de Software Seguro
Actividad	Proyecto Integrador del Primer Parcial
Producto	Backend V1: AUTH y STEGO
Modalidad	Trabajo grupal
Integrantes	Danna Andrade
	David Pilaguano
	Erick Tufiño
Docente	Geovanny Cudco
Fecha de entrega	4 de noviembre de 2026

Resumen

Este informe presenta el diseño, la implementación y la evaluación de un backend compuesto por dos microservicios REST independientes. AUTH administra las identidades y los roles mediante PostgreSQL, almacena las contraseñas utilizando Argon2id, emite JSON Web Tokens firmados con RS256 y toma decisiones de autorización según las asignaciones vigentes. STEGO recibe imágenes PNG, verifica la autenticidad de los tokens, obtiene una decisión de autorización actual desde AUTH y aplica un análisis estadístico sobre los bits menos significativos de los canales RGB. Los resultados se registran en SQLite junto con indicadores, hash SHA-256 y política asociada.

La solución se ejecuta con Docker Compose y separa el procesamiento de imágenes de la persistencia de identidades. La evaluación incluye doce escenarios funcionales y de seguridad, pruebas adicionales con archivos no válidos, revisión de auditoría y contraste entre muestras normales e imágenes modificadas mediante LSB. Los ensayos muestran rechazo de accesos no autorizados y también evidencian falsos positivos y negativos que delimitan la capacidad del detector.

Palabras clave: microservicios, JWT, RBAC, autenticación, LSB, esteganografía, seguridad de aplicaciones.

Índice

1. Introducción **1**
1.1. Objetivo general . . . 1
1.2. Objetivos específicos . . . 1
1.3. Alcance . . . 1

2. Arquitectura y límites de confianza **1**
2.1. Separación de servicios . . . 1
2.2. Independencia operativa . . . 2
2.3. Tecnologías de implementación . . . 3

3. Identidad y persistencia de AUTH **3**
3.1. Modelo entidad–relación . . . 3
3.2. Integridad y preparación de datos . . . 4

4. Autenticación y autorización **4**
4.1. Contraseñas y proceso de inicio de sesión . . . 4
4.2. Estructura y validación del JWT . . . 4
4.3. RS256 y distribución de claves . . . 4
4.4. Política RBAC y propiedad de resultados . . . 5
4.5. Revocación, cierre de sesión y respuestas . . . 5

5. Integración y comunicación entre microservicios **6**
5.1. Solicitud de autorización interna . . . 6
5.2. Denegación por defecto . . . 6

6. API REST y especificaciones OpenAPI **6**
6.1. Contrato de AUTH . . . 6
6.2. Contrato de STEGO . . . 7
6.3. Ejemplo de autenticación y análisis . . . 7

7. Procesamiento y detección esteganográfica **7**
7.1. Admisión del archivo . . . 7
7.2. Extracción de indicadores LSB . . . 8
7.3. Criterios de clasificación y política . . . 8
7.4. Muestras y resultados experimentales . . . 9
7.5. Limitaciones del método . . . 9

8. Persistencia de resultados y auditoría **10**

8.1. Registro de análisis en STEGO 10
8.2. Bitácoras y correlación entre servicios 10

9. Análisis de riesgos y controles **10**
9.1. Criterio de valoración 10
9.2. Enfoques y normas de referencia 12

10. Pruebas, resultados y evidencia reproducible **12**
10.1. Batería oficial T01–T12 12
10.2. Pruebas adicionales de tokens 13
10.3. Validación de carga y consistencia 13
10.4. Pruebas unitarias e integración 13

11. Instalación y puesta en marcha **13**
11.1. Requisitos y estructura de entrega 13
11.2. Secuencia de arranque 14
11.3. Prueba manual de los servicios 14
11.4. Persistencia y operación 14

12. Discusión y limitaciones **14**

13. Conclusiones **15**

Referencias **15**

A. Resumen de archivos del proyecto **16**

B. Lista de comprobación para la sustentación **16**

1 Introducción

La primera entrega del Proyecto Integrador comprende los servicios de identidad, autorización y evaluación inicial de imágenes de una futura plataforma de comunicación segura. El alcance se limita deliberadamente al backend. La autenticación comprueba quién solicita una operación; la autorización establece si ese sujeto conserva el permiso necesario en el momento de realizarla.

La separación entre AUTH y STEGO evita que el servicio que procesa archivos administre directamente las identidades o consulte las tablas de usuarios. Esta arquitectura permite reproducir cambios de permisos, rechazar sesiones inválidas y comprobar el comportamiento ante fallas del servicio de autorización. La detección de posibles datos ocultos se aborda como un análisis estadístico real, no como una clasificación simulada.

1.1 Objetivo general

Implementar y evaluar dos microservicios REST independientes, uno para autenticación y autorización mediante JWT y RBAC dinámico y otro para detección estadística de posibles modificaciones esteganográficas en imágenes, con controles de acceso y pruebas reproducibles.

1.2 Objetivos específicos

- Modelar y persistir la relación muchos a muchos entre usuarios y roles, con integridad referencial y unicidad.
- Emitir JWT firmados, validar sus atributos y resolver los permisos a partir del estado actual de PostgreSQL.
- Integrar AUTH y STEGO mediante un canal interno protegido y una decisión de autorización por operación.
- Validar y procesar imágenes PNG mediante indicadores estadísticos LSB y registrar los resultados.
- Comprobar respuestas adversas, revocación de permisos, aislamiento de datos y auditoría mediante pruebas ejecutables.

1.3 Alcance

Se incluyen los microservicios AUTH y STEGO, sus persistencias, las APIs REST, scripts de configuración, Docker Compose, colección de pruebas e imágenes de referencia. No se implementan interfaz gráfica, chat, mensajería, cifrado extremo a extremo de conversaciones ni administración de salas. El detector no extrae mensajes ni demuestra de forma concluyente su existencia.

2 Arquitectura y límites de confianza

2.1 Separación de servicios

AUTH y STEGO son aplicaciones NestJS distintas: disponen de código, dependencias, Dockerfile, puerto, ejecución y responsabilidades diferenciadas. Docker Compose incorpora un contenedor de PostgreSQL como infraestructura complementaria. La persistencia de STEGO se realiza en SQLite con un

volumen propio.

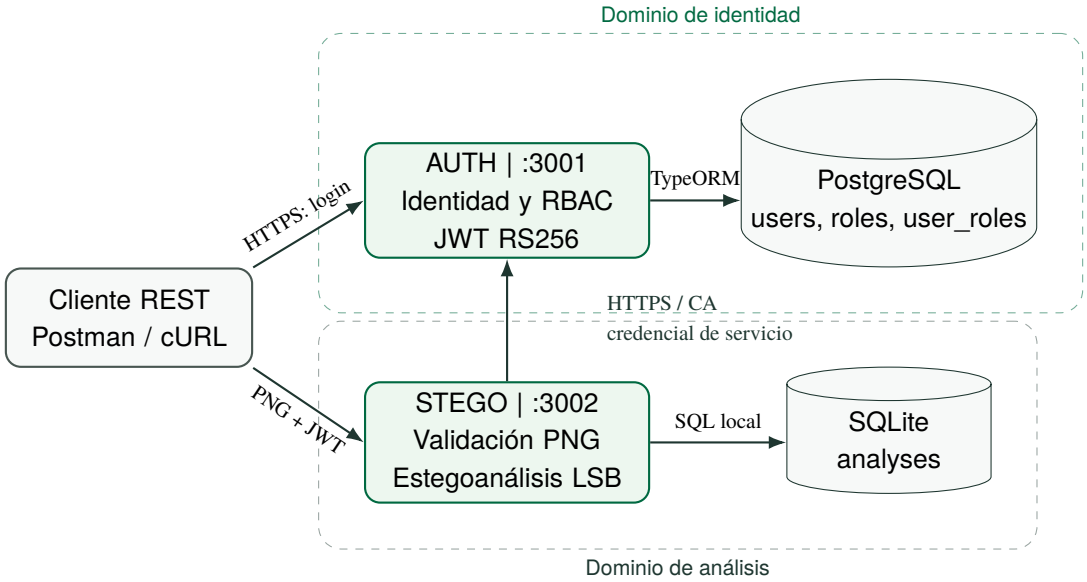


Figura 1: Arquitectura del backend y fronteras de confianza.

El cliente obtiene un JWT mediante AUTH y lo utiliza para enviar una imagen a STEGO. Este último verifica localmente la firma y los atributos del token; posteriormente solicita a AUTH una decisión específica por acción. La comunicación interna utiliza HTTPS con una autoridad certificadora de desarrollo y autenticación del servicio mediante `x-service-token`. La clave privada de firma pertenece a AUTH, mientras que STEGO sólo dispone de la pública.

2.2 Independencia operativa

La separación se manifiesta en los servicios `auth`, `stego` y `auth-db` declarados en Compose. Se pueden detener y reiniciar las dos APIs por separado. STEGO requiere AUTH para autorizar operaciones protegidas; por tanto, independencia de despliegue no implica independencia funcional de la política de acceso. Si AUTH no puede responder, STEGO deniega la operación sin procesar el archivo.

Tabla 1: Distribución de responsabilidades.

Componente	Responsabilidad	Persistencia y claves
AUTH	Usuarios, roles, credenciales, JWT y decisión RBAC.	PostgreSQL; clave privada RSA; certificado TLS.
STEGO	Validación de archivos, análisis LSB, clasificación y consulta de resultados.	SQLite; clave pública JWT; CA TLS.
auth-db	Servicio de base de datos para AUTH.	Volumen PostgreSQL independiente.

2.3 Tecnologías de implementación

Tabla 2: Tecnologías y finalidad técnica.

Tecnología	Uso dentro del sistema
NestJS y TypeScript	Exposición de APIs, inyección de dependencias, servicios, controladores, guards y DTO.
TypeORM y PostgreSQL	Persistencia relacional de identidades, índices, claves foráneas y asignaciones de roles.
Argon2id	Derivación y verificación segura de contraseñas almacenadas.
JWT RS256	Firma asimétrica de credenciales de acceso y verificación con clave pública.
Sharp y file-type	Decodificación de PNG y verificación del formato de archivo a partir de su contenido.
SQLite y better-sqlite3	Registro persistente de análisis en STEGO.
Docker Compose	Construcción, inicialización, red de servicios y volúmenes persistentes.
Swagger / OpenAPI	Descripción y exploración de las interfaces REST.

3 Identidad y persistencia de AUTH

3.1 Modelo entidad–relación

El modelo relacional utiliza tres entidades principales: `users`, `roles` y `user_roles`. La tabla intermedia materializa la relación N:M y dispone de dos claves foráneas y una restricción de unicidad sobre el par usuario–rol. El diseño permite que un usuario acumule varios roles y que un mismo rol se asigne a distintos usuarios.

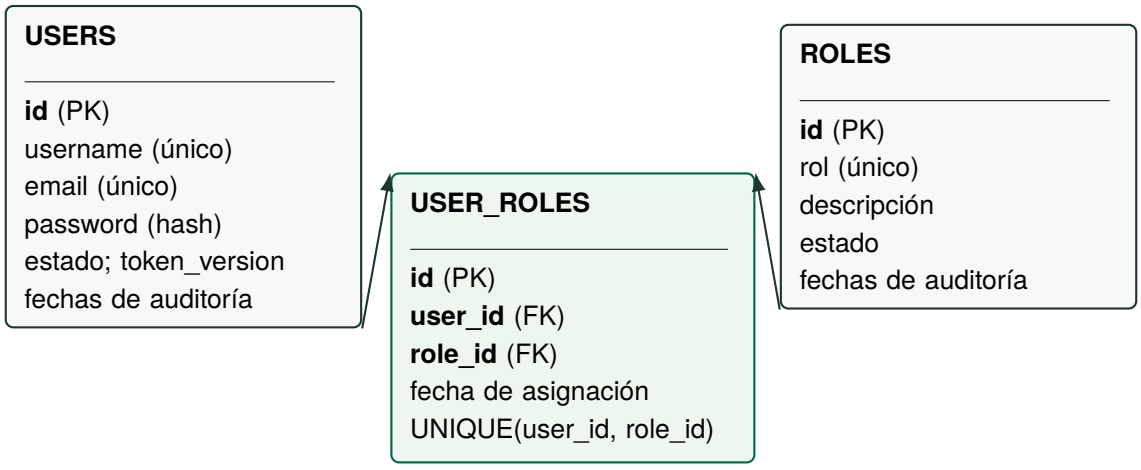


Figura 2: Modelo lógico N:M de usuarios y roles.

La entidad `User` incluye además campos de identificación y el contador `tokenVersion`. Las entidades `User` y `Role` conservan atributos de estado y borrado lógico para impedir que asignaciones a registros desactivados otorguen privilegios. `UserRole` incorpora índices por usuario y rol y una restricción única compuesta. La tabla `analyses` de STEGO no referencia directamente la base AUTH: guarda el UUID del solicitante como valor lógico.

3.2 Integridad y preparación de datos

Los servicios de dominio delegan la persistencia a repositorios TypeORM. Las validaciones de DTO reducen entradas malformadas, pero las restricciones únicas y las claves foráneas permanecen en la base de datos para conservar la integridad ante solicitudes concurrentes.

El arranque inicial prepara los roles `ADMIN`, `ANALYST` y `USER` y la cuenta administrativa de demostración. El script `scripts/setup-demo.ps1` prepara las identidades y asignaciones empleadas en la batería de pruebas. La base de datos de AUTH se prepara con la migración inicial de TypeORM `auth/src/migrations/1793740000000-InitialIdentity.ts`. En la configuración publicada, `synchronize:false` y `migrationsRun:true` mantienen el esquema bajo control de esa migración antes de cargar los datos de demostración.

Comprobación de la relación N:M. La demostración usa un usuario con roles `ANALYST` y `USER`, mientras que `USER` se asigna también a otra identidad. Un segundo intento de crear el mismo par usuario–rol produce HTTP 409 y no genera otra relación.

4 Autenticación y autorización

4.1 Contraseñas y proceso de inicio de sesión

Los registros de usuario almacenan un hash de contraseña calculado con Argon2id. En un inicio de sesión, AUTH localiza la identidad, obtiene el hash y utiliza `argon2.verify` para comprobar la contraseña sin recuperarla. La columna de hash no se selecciona normalmente en consultas de presentación. El acceso de login aplica una limitación de intentos.

4.2 Estructura y validación del JWT

El token firmado se estructura en tres segmentos codificados con Base64URL: *header*, *payload* y *signature*. El payload utilizado incluye `sub`, `username`, `typ`, `tokenVersion` y atributos estándar de emisor, audiencia y vigencia. No contiene los roles como autoridad de permisos.

Tabla 3: Atributos del token y validaciones.

Atributo	Finalidad	Control aplicado
`alg=RS256`	Especifica firma RSA con SHA-256.	Lista explícita de algoritmos permitidos.
`sub`	Identifica al usuario autenticado.	Búsqueda de usuario activo en AUTH.
`iss`	Identifica al emisor.	Comparación con emisor configurado.
`aud`	Indica la audiencia esperada.	Comparación con audiencia configurada.
`exp`	Fecha límite de validez.	Rechazo de tokens expirados.
`typ`	Identifica el propósito del token.	Debe ser `access`.
`tokenVersion`	Versión vigente de sesión.	Comparación con valor persistido en `users`.

4.3 RS256 y distribución de claves

RS256 utiliza una clave privada para firmar y una clave pública para verificar. AUTH conserva la clave privada y expone a STEGO únicamente el material público necesario para validar la autenticidad. Esta

disposición evita que STEGO tenga una credencial con la que pueda emitir nuevos JWT. La firma no cifra el contenido: los claims pueden leerse, pero una modificación no autorizada invalida la firma.

Una firma válida tampoco prueba que la asignación de roles siga vigente. Para cada análisis o consulta de resultado, STEGO obtiene una nueva decisión de AUTH, que consulta las relaciones activas en PostgreSQL. Con esta separación, retirar `ANALYST` impide inmediatamente una nueva operación del usuario, aunque su JWT no haya vencido.

4.4 Política RBAC y propiedad de resultados

Tabla 4: Matriz de roles y operaciones.

Operación	ADMIN	ANALYST	USER
Consultar perfil propio	Sí	Sí	Sí
Crear y actualizar usuarios	Sí	No	No
Crear y actualizar roles	Sí	No	No
Asignar y retirar roles	Sí	No	No
Analizar PNG	Sí	Sí	No
Consultar resultado propio	Sí	Sí	No
Consultar resultado ajeno	Sí	No	No

La verificación de un resultado incluye dos pasos: autorización general de la operación de lectura y comprobación de propiedad. En la implementación, un usuario autorizado puede consultar sus propios análisis y el rol `ADMIN` puede consultar también los de otros usuarios. El identificador del recurso no constituye permiso por sí mismo.

4.5 Revocación, cierre de sesión y respuestas

Retirar una asignación activa hace que la consulta posterior a AUTH carezca del permiso correspondiente: el JWT sigue siendo auténtico, pero STEGO devuelve HTTP 403. El cierre de sesión incrementa `tokenVersion` en AUTH; un JWT anterior conserva el valor previo y se rechaza con HTTP 401. Si AUTH no puede tomar una decisión válida, STEGO responde HTTP 503 y no analiza la imagen. La tabla 5 resume estos casos.

Tabla 5: Respuestas de seguridad y validación.

HTTP	Condición	Efecto
401	Token ausente, alterado, vencido o sesión revocada.	Se rechaza antes del análisis.
403	Identidad válida sin permiso o resultado ajeno.	Se deniega la operación solicitada.
413	Archivo demasiado grande.	No se procesa ni se persiste.
415	Formato, firma, extensión o MIME incompatibles.	Se rechaza la carga.
422	PNG corrupto o dimensiones no aceptadas.	Fallo controlado de decodificación.
503	AUTH inaccesible o decisión no verificable.	Denegación por defecto.

5 Integración y comunicación entre microservicios

5.1 Solicitud de autorización interna

STEGO invoca `POST /internal/authorization/check` por HTTPS, incluye una credencial de servicio en la cabecera `x-service-token` y envía el token del usuario junto con la acción solicitada. AUTH verifica la identidad del servicio llamante, revalida la sesión y obtiene los roles activos antes de responder. El mensaje también propaga `x-request-id` para enlazar los eventos de auditoría de ambas aplicaciones.

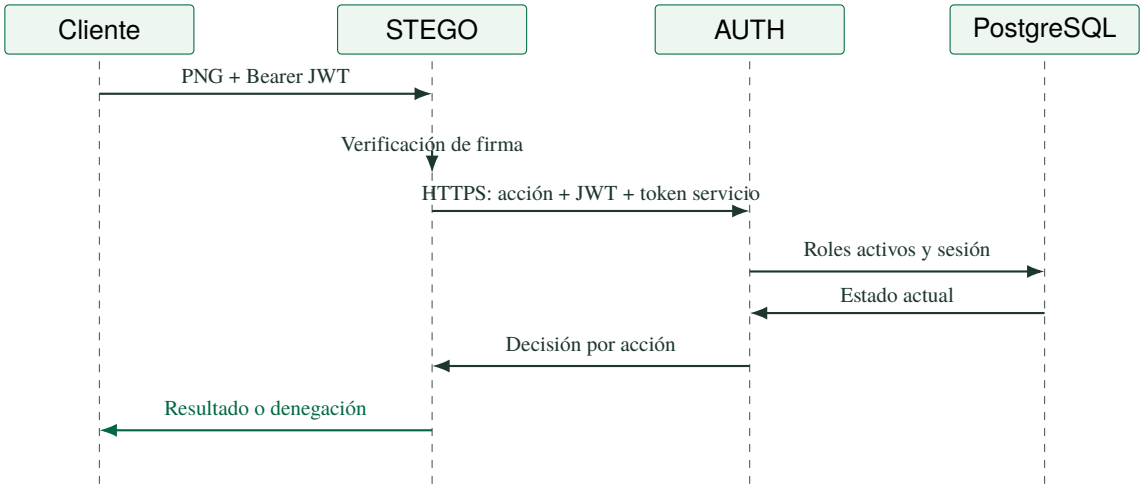


Figura 3: Secuencia de autenticación y decisión RBAC.

5.2 Denegación por defecto

Los tiempos de espera, errores de red y respuestas internas sin el contrato esperado no otorgan permisos implícitos. Cuando la autoridad de autorización está ausente, el controlador de STEGO no llega a ejecutar la decodificación ni el análisis estadístico. Esta regla es observable en el escenario T08.

6 API REST y especificaciones OpenAPI

6.1 Contrato de AUTH

La interfaz AUTH dispone de login y perfil, gestión administrativa y un endpoint de autorización destinado a STEGO. Los prefijos exactos utilizados en la configuración inspeccionada son `/api` para operaciones públicas y administrativas y la ruta `/internal/authorization/check` para comunicación interna.

Tabla 6: Operaciones principales de AUTH.

Método	Ruta	Acceso
POST	`/api/auth/login`	Público; límite de intentos.
GET	`/api/auth/profile`	JWT válido.
POST	`/api/auth/logout`	JWT válido.
POST, GET	`/api/users`	ADMIN.
GET, PATCH	`/api/users/:id`	ADMIN.

Método	Ruta	Acceso
POST, GET	`/api/roles`	ADMIN.
PATCH	`/api/roles/:id`	ADMIN.
POST, GET	`/api/user-roles`	ADMIN.
DELETE	`/api/user-roles/:id`	ADMIN.
POST	`/internal/authorization/check`	STEGO autenticado.

6.2 Contrato de STEGO

Tabla 7: Operaciones principales de STEGO.

Método	Ruta	Acceso y datos
POST	`/api/steganography/analyze`	ADMIN/ANALYST; `multipart/form-data`, campo `file`.
GET	`/api/steganography/results/:id`	JWT, permiso vigente y validación de propiedad.

La documentación interactiva se construye en cada aplicación con `SwaggerModule` y `DocumentBuilder`. Se incorporan dos contratos OpenAPI 3 en el directorio `openapi`: uno para AUTH y otro para STEGO. Ambos describen recursos, esquemas de solicitud y respuestas relevantes, y pueden contrastarse con la documentación Swagger de los servicios en ejecución.

6.3 Ejemplo de autenticación y análisis

```
POST https://localhost:3001/api/auth/login
Content-Type: application/json

{"identity":"analyst","password":"<credencial_demo>"}

POST http://localhost:3002/api/steganography/analyze
Authorization: Bearer <JWT>
Content-Type: multipart/form-data

file=@samples/stego/lsb-random-payload.png
```

7 Procesamiento y detección esteganográfica

7.1 Admisión del archivo

El controlador recibe una única imagen en `multipart/form-data`. El límite de carga es de 5 MiB y el de decodificación es de 16 millones de píxeles. La verificación considera el tamaño, el MIME declarado, la extensión y la firma real del archivo. Sharp decodifica el contenido PNG y rechaza archivos corruptos o incompatibles. La autorización precede al análisis de píxeles.

El soporte implementado en esta versión corresponde a PNG; no se afirma compatibilidad completa con BMP ni con otras técnicas. Los bytes de la imagen se utilizan durante el procesamiento y no se

conservan como archivo de acceso público. La persistencia retiene metadatos, indicadores y huellas de integridad.

7.2 Extracción de indicadores LSB

Tras decodificar la imagen, el detector convierte los canales de color a una secuencia de n bytes RGB. Para cada posición i se extrae el bit menos significativo:

$$b_i = x_i \,\&\, 1, \qquad b_i \in \{0, 1\}. \tag{1}$$

Se calculan la proporción de unos p, la tasa de transiciones consecutivas t y el estadístico de chi-cuadrado respecto de un balance de referencia del 50 %:

$$p = \frac{1}{n} \sum_{i=1}^{n} b_i, \tag{2}$$

$$t = \frac{1}{n-1} \sum_{i=2}^{n} \mathbb{1}(b_i \neq b_{i-1}), \tag{3}$$

$$\chi^2 = \frac{(o - n/2)^2}{n/2} + \frac{((n-o) - n/2)^2}{n/2}, \tag{4}$$

con $o = \sum_i b_i$. El puntaje de anomalía combina la cercanía de p y t al valor $0{,}5$:

$$s = \frac{\text{máx}(0, 1 - 2|p - 0{,}5|) + \text{máx}(0, 1 - 2|t - 0{,}5|)}{2}. \tag{5}$$

El chi-cuadrado se registra como indicador complementario, pero no determina directamente la clasificación. Un puntaje cercano a 1 significa que las dos medidas se aproximan al patrón aleatorio esperado por esta heurística; *no significa que exista una probabilidad del 100 % de esteganografía*.

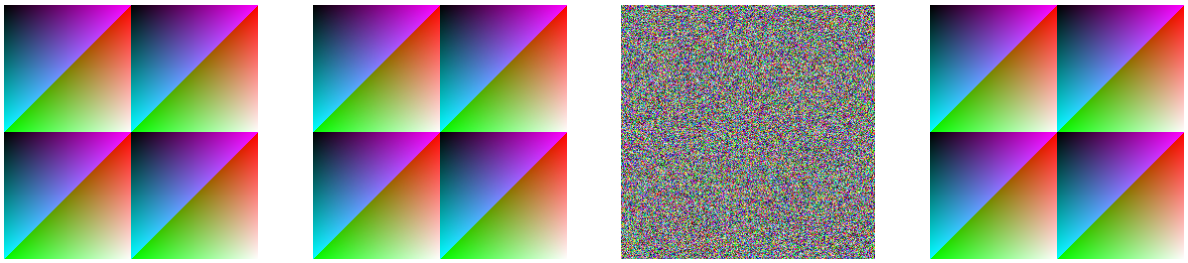
7.3 Criterios de clasificación y política

El sistema registra tres clases de resultado: `sin_indicios`, `no_concluyente` y `sospechoso`. Una falla técnica de admisión o procesamiento se expresa mediante el correspondiente error HTTP, sin insertar un análisis válido. La clasificación se determina mediante:

$$C(s) = \begin{cases} \text{sospechoso}, & s \geq 0{,}97, \\ \text{no_concluyente}, & 0{,}85 \leq s < 0{,}97, \\ \text{sin_indicios}, & s < 0{,}85. \end{cases} \tag{6}$$

La política registrada es `cuarentena` para la clase sospechosa y `advertencia` en los demás casos. El valor `cuarentena` es una decisión almacenada en el registro; la implementación revisada no incluye un subsistema independiente de aislamiento físico del archivo.

7.4 Muestras y resultados experimentales



(a) Referencia **(b)** LSB aleatorio **(c)** Ruido normal **(d)** LSB disperso

Figura 4: Muestras utilizadas para examinar resultados y límites de la heurística.

Tabla 8: Resultados de las pruebas sobre muestras PNG.

Muestra	Puntaje	Clase	Observación
Referencia	0.000000	sin_indicios	Sin señal LSB para esta heurística.
Carga LSB aleatoria	0.997714	sospechoso	Señal positiva esperada.
Ruido sin modificar	≈1	sospechoso	Falso positivo observado.
Carga LSB dispersa	≈0.08	sin_indicios	Falso negativo observado.
Patrón intermedio	≈0.94	no_concluyente	Evidencia estadística intermedia.

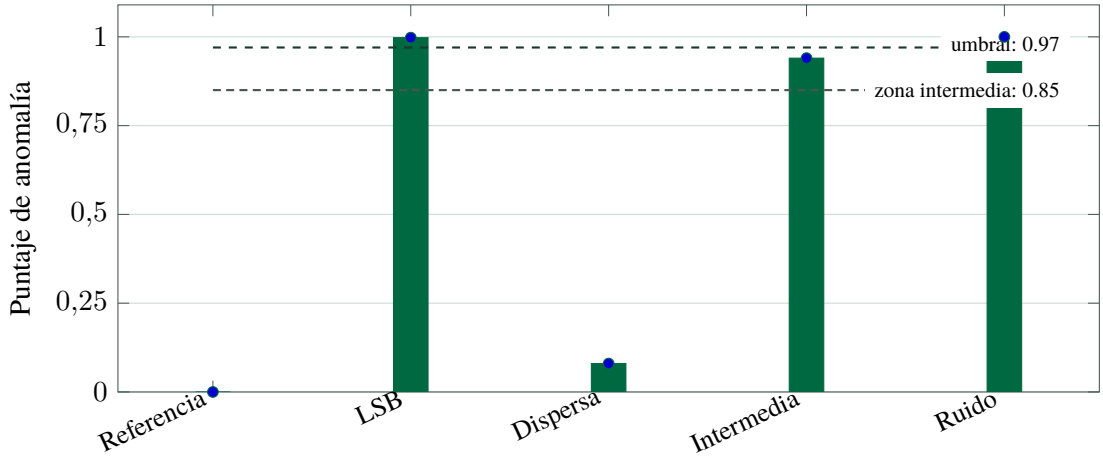


Figura 5: Puntajes registrados y umbrales de clasificación.

7.5 Limitaciones del método

El análisis favorece patrones de bits con equilibrio y alternancia próximos a 0.5. Esto permite identificar ciertas cargas LSB aleatorias, pero las texturas naturales o el ruido pueden imitar esos indicadores, mientras que una carga dispersa o una técnica adaptativa puede no alterar suficientemente las métricas. El método tampoco detecta de manera general otros dominios de ocultamiento, como transformaciones de frecuencia o modificaciones fuera de los canales analizados. Los resultados constituyen alertas estadísticas sujetas a interpretación.

8 Persistencia de resultados y auditoría

8.1 Registro de análisis en STEGO

La tabla `analyses` se gestiona con SQLite y conserva `id`, `user_id`, `filename`, `sha256`, `technique`, `status`, `indicators`, `action`, `limitations` y `created_at`. Los indicadores incluyen dimensiones, cantidad de muestras, proporción de bits uno, transiciones, chi-cuadrado y puntaje.

El hash SHA-256 identifica los bytes exactos de la imagen procesada, pero no acredita que el contenido sea inocuo. El modo WAL y el volumen `stego_data` permiten conservar registros tras reiniciar STEGO. En los ensayos documentados, la cantidad permaneció en 12 antes y después del reinicio.

8.2 Bitácoras y correlación entre servicios

AUTH registra inicios de sesión válidos y fallidos, decisiones de autorización y eventos relevantes de sesión. STEGO registra denegaciones, indisponibilidad de AUTH, inicio y final de análisis, clasificación y puntaje. Los eventos se emiten como JSON e incluyen marca temporal e identificador de solicitud. El `requestId` enlaza una operación del cliente con su autorización interna.

Tabla 9: Campos principales de auditoría.

Campo	Información registrada
`timestamp`	Fecha y hora del evento.
`event`	Tipo de operación o decisión.
`requestId`	Identificador de correlación entre servicios.
`userId`	Identidad relacionada, cuando existe.
`action`, `allowed`	Operación autorizada o denegada.
`analysisId`, `status`	Resultado de la tarea de STEGO.

Los logs se inspeccionan mediante `docker compose logs`. Los eventos de auditoría no necesitan reproducir contraseñas, claves o JWT completos para explicar cada decisión. La conservación centralizada y resistente a alteraciones queda fuera del alcance de esta versión.

9 Análisis de riesgos y controles

9.1 Criterio de valoración

La matriz emplea una valoración cualitativa de probabilidad e impacto (bajo, medio y alto). El nivel de riesgo resume la exposición inicial; el riesgo residual considera los controles existentes y las limitaciones de la demostración. La matriz se vincula con los activos del backend, no con capacidades aún no construidas.

Tabla 10: Matriz de activos, amenazas, vulnerabilidades, riesgos y controles.

Activo	Amenaza	Vulnerabilidad o condición	Impacto	Prob.	Riesgo	Control / tratamiento	Residual / evidencia
Credenciales	Fuerza bruta	Intentos repetidos de acceso	Alto	Media	Alto	Argon2id, respuesta genérica y límite de login.	Medio; T02.
Base de identidad	Exposición de hashes	Filtración de base de datos	Alto	Baja	Medio	Hash Argon2id, exclusión del campo en consultas normales.	Medio; entidades AUTH.
JWT	Falsificación de identidad	Alteración de claims o algoritmo	Alto	Media	Alto	RS256, firma, algoritmo fijo, issuer, audience y expiración.	Bajo; T03 y variantes.
Clave privada RSA	Emisión ilegítima de tokens	Compromiso del material de firma	Alto	Baja	Alto	Clave privada sólo en AUTH; separación de montajes.	Medio; Compose.
Sesiones	Reutilización tras logout	Token válido hasta caducar	Alto	Media	Alto	Versionado de sesión y rechazo de token antiguo.	Bajo; logout 401.
Roles	Elevación de privilegios	Confiar en permisos desactualizados	Alto	Media	Alto	Consulta dinámica a PostgreSQL por operación.	Bajo; T07.
Relación N:M	Permisos inconsistentes	Duplicación de asignaciones	Medio	Media	Medio	FK e índice UNIQUE(user_id,role_id).	Bajo; T05–T06.
API de resultados	Acceso horizontal	Uso de identificador ajeno	Alto	Media	Alto	RBAC y comprobación de propietario/ADMIN.	Bajo; T11.
Canal interno	Suplantación de STEGO	Credencial de servicio comprometida	Alto	Baja	Medio	HTTPS con CA y cabecera de identidad del servicio.	Medio; sin mTLS.
Disponibilidad AUTH	Interrupción de autorización	Dependencia operativa de STEGO	Alto	Media	Alto	Timeout y fallo cerrado sin procesamiento.	Medio; T08.
Entrada PNG	Archivo disfrazado	Confiar sólo en extensión o MIME	Alto	Media	Alto	Comprobación de firma, tipo y decodificación estricta.	Bajo; T10.
Recursos de STEGO	Agotamiento de memoria	Carga grande o dimensiones extremas	Alto	Media	Alto	Límites de 5 MiB, 16 Mpx y un archivo.	Bajo/medio; T10.
Logs	Pérdida de trazabilidad	Ausencia de correlación	Medio	Media	Medio	Auditoría JSON y Request ID compartido.	Bajo; T12.
Dependencias	Explotación de paquete vulnerable	Vulnerabilidades de terceros	Alto	Media	Alto	Seguimiento de auditoría de dependencias y actualización controlada.	Medio; npm audit.
Detector LSB	Falso positivo	Ruido legítimo con patrón aleatorio	Medio	Media	Medio	Clasificación indicativa y revisión del resultado.	Medio; muestra ruido.
Detector LSB	Falso negativo	Inserción dispersa/adaptativa	Alto	Media	Alto	Declaración de alcance; corpus de prueba complementario.	Alto; muestra dispersa.

9.2 Enfoques y normas de referencia

Zero Trust. Las fronteras de confianza de la figura 1 requieren verificar la identidad del sujeto, la identidad del servicio llamante y el permiso actual de cada operación. Un JWT auténtico no constituye autorización permanente.

Secure by Design. La separación de claves, los permisos mínimos, la validación del contenido y la denegación ante fallos están incorporados al flujo principal, en lugar de quedar como funciones optativas.

Shift Left Security. Los controles se comprueban desde la implementación mediante pruebas unitarias, funcionales y negativas ejecutables; los casos adversos incluyen tokens alterados, archivos malformados y fallas de comunicación.

Los controles se relacionan con la gestión sistemática de riesgos de seguridad de la información descrita por ISO/IEC 27001:2022 y con los conceptos de seguridad de aplicaciones de ISO/IEC 27034-1:2011. El sistema aplica prácticas técnicas pertinentes a esos marcos, sin que ello constituya certificación ni una evaluación formal de conformidad.

10 Pruebas, resultados y evidencia reproducible

10.1 Batería oficial T01–T12

Los escenarios se identifican con la numeración definida en la especificación del Proyecto Integrador. Los resultados consignados corresponden a la evidencia de ejecución reunida durante el desarrollo y a los scripts del proyecto.

Tabla 11: Escenarios mínimos, resultados registrados y forma de verificación.

ID	Escenario	Resultado registrado	Verificación
T01	Iniciar y detener AUTH y STEGO separadamente.	Dos procesos e interfaces independientes; infraestructura separada.	`test-independence.ps1`
T02	Credenciales válidas e inválidas.	Emisión de JWT y rechazo de contraseña incorrecta.	`test-core-security.ps1`
T03	Token ausente, manipulado o vencido.	HTTP 401 en todos los casos.	`test-core-security.ps1`; JWT especiales.
T04	USER intenta analizar PNG.	HTTP 403, sin privilegio ANALYST/ADMIN.	`test-core-security.ps1`
T05	Usuario con dos roles; un rol en dos usuarios.	Asignaciones N:M persistidas.	Consulta JOIN y Postman.
T06	Repetir asignación usuario–rol.	HTTP 409; asociación única.	`test-core-security.ps1`
T07	Retirar rol y reutilizar JWT vigente.	Análisis previo permitido; siguiente HTTP 403.	Revocación y mismo JWT.
T08	Interrumpir AUTH.	STEGO HTTP 503; no ejecuta análisis.	`test-fail-closed.ps1`

ID	Escenario	Resultado registrado	Verificación
T09	Imagen original e imagen con LSB.	Puntajes 0 y 0.997714; clases distintas.	`test-detector.ps1`
T10	Archivo grande, corrupto o formato falso.	413, 422, 422, 415 y 415; registros sin cambio.	`test-t10.ps1`
T11	Consultar resultado de otra identidad.	HTTP 403.	`test-core-security.ps1`
T12	Correlacionar bitácoras de accesos y análisis.	Eventos JSON y Request ID.	Logs AUTH/STEGO.

10.2 Pruebas adicionales de tokens

Se ejercitaron modificaciones de `username`, `sub` y roles ficticios, así como emisor incorrecto, audiencia incorrecta, token vencido y encabezado con `alg=none`. Todas las variantes fueron denegadas con HTTP 401. La causa se distingue entre firma inválida, claims inválidos, algoritmo inadmisible y sesión revocada, según corresponda. La batería local puede ejecutarse con `scripts/test-jwt-special.ps1`.

10.3 Validación de carga y consistencia

En T10 se observaron cinco respuestas para entradas incompatibles: tamaño superior a 5 MiB (413), PNG truncado (422), 25 millones de píxeles (422), GIF (415) y JPEG con extensión PNG (415). El número de análisis persistidos permaneció sin incrementarse tras esos rechazos. La prueba de reinicio de STEGO mantuvo 12 registros antes y después.

10.4 Pruebas unitarias e integración

El proyecto dispone de pruebas automatizadas con Jest para AUTH y Vitest para STEGO, además de scripts de extremo a extremo y de integración mediante peticiones reales. Los reportes del equipo registran compilaciones exitosas y ejecución satisfactoria de las pruebas. La colección Postman permite comprobar solicitudes HTTP con identidades y roles diferentes, y las muestras PNG reproducen las condiciones evaluadas por el detector.

11 Instalación y puesta en marcha

11.1 Requisitos y estructura de entrega

Se requiere Docker Desktop con Compose, PowerShell compatible con los scripts y OpenSSL para crear material criptográfico de desarrollo. El repositorio incorpora dos directorios de aplicación, archivos de dependencias, Dockerfiles, ejemplos de variables de entorno, migración de identidad, scripts de preparación, colección Postman y muestras PNG. El código fuente se conserva en `https://github.com/Dval05/DES-SW-SEGURO-36902-DDE`, bajo la ruta `Unidad 1/Proyecto/Codigo`.

```
Codigo/
  auth/                # API de identidad
  stego/               # API de analisis
```

```
scripts/              # preparacion y pruebas
samples/              # imagenes de ensayo
docker-compose.yml
postman_collection.json
postman_environment.json
README.md
auth/.env.example
stego/.env.example
```

11.2 Secuencia de arranque

Desde la carpeta `Codigo`, con Docker Desktop iniciado, el script `scripts/start-demo.ps1` realiza la preparación de material de desarrollo, verifica Docker Compose, construye las imágenes, inicia los servicios y crea las cuentas de demostración. El mismo proceso puede ejecutarse paso a paso:

```
.\scripts\generate-secrets.ps1
docker compose up -d --build
docker compose ps
.\scripts\setup-demo.ps1
```

El generador conserva el par de claves y los certificados existentes. El script de demostración debe ejecutarse después de que AUTH esté operativo. Se puede comprobar cada aplicación desde su API y revisar el estado de los tres servicios mediante Compose.

11.3 Prueba manual de los servicios

AUTH utiliza HTTPS en el puerto local 3001 y STEGO expone HTTP de desarrollo en el 3002. El login recibe una identidad y contraseña en la ruta `/api/auth/login`; después, STEGO recibe el JWT como credencial Bearer. Para analizar una imagen se usa un formulario multipart con el campo `file`. Swagger queda disponible al iniciar las aplicaciones.

11.4 Persistencia y operación

Los volúmenes `auth_data` y `stego_data` conservan PostgreSQL y SQLite respectivamente al reiniciar contenedores. Para ejecutar T08 se puede detener temporalmente AUTH, repetir una solicitud protegida y restaurar el servicio. El cierre del entorno con `docker compose down` no borra por sí mismo esos volúmenes.

```
.\scripts\test-core-security.ps1
.\scripts\test-jwt-special.ps1
.\scripts\test-t10.ps1
.\scripts\test-detector.ps1
.\scripts\test-independence.ps1
.\scripts\test-fail-closed.ps1
```

12 Discusión y limitaciones

El proyecto satisface la separación de responsabilidades exigida para el Backend V1. La validación de identidad y la comprobación dinámica de permisos producen resultados distintos ante tokens inválidos y

roles insuficientes. Los escenarios de revocación y caída de AUTH permiten verificar que la autorización no depende exclusivamente del contenido del JWT.

El detector procesa realmente los píxeles y calcula métricas reproducibles, pero su alcance es heurístico: ruido legítimo puede resultar sospechoso y una carga LSB dispersa puede pasar inadvertida. La decisión de cuarentena se registra como política; no sustituye un servicio de aislamiento. La implementación está orientada a ejecución académica local. La migración inicial versionada satisface la preparación del esquema requerida en esta entrega. Una operación distribuida sostenida exigiría, adicionalmente, terminación HTTPS externa en STEGO, respaldos y retención duradera de auditoría, así como una evaluación más amplia del método estadístico.

13 Conclusiones

1. Se implementó una arquitectura de dos microservicios con responsabilidades separadas, configuraciones independientes y persistencia específica para identidad y análisis de imágenes.
2. AUTH distingue autenticación de autorización: la firma RS256 acredita el origen del JWT y la política RBAC depende de asignaciones activas en PostgreSQL, lo que permite que una revocación se refleje sin esperar a que expire el token.
3. STEGO incorpora controles de tipo, tamaño y decodificación antes de registrar un análisis estadístico real basado en LSB; sus resultados incluyen métricas, clasificación y limitaciones.
4. La batería T01–T12 y las pruebas adversas permiten evaluar el funcionamiento, la integridad de las relaciones, el fallo cerrado, el aislamiento de resultados y la trazabilidad.
5. Los resultados muestran tanto la utilidad de una detección indicativa como sus límites frente al ruido natural y las cargas poco densas, lo que evita interpretar las alertas como conclusiones forenses.

Referencias

[1] Departamento de Ciencias de la Computación. *Proyecto Integrador del Primer Parcial: Backend – Autenticación JWT/RBAC y detección de esteganografía*. Desarrollo de Software Seguro, 2026.

[2] ISO/IEC. *ISO/IEC 27001:2022. Information security management systems – Requirements*. `https://www.iso.org/standard/27001`.

[3] ISO/IEC. *ISO/IEC 27034-1:2011. Application security – Overview and concepts*. `https://www.iso.org/standard/44378.html`.

[4] OWASP Foundation. *Application Security Verification Standard, versión 5.0.0*. ASVS.

[5] OWASP Foundation. *File Upload Cheat Sheet*. OWASP Cheat Sheet Series.

[6] Jones, M.; Bradley, J.; Sakimura, N. *JSON Web Token (JWT)*, RFC 7519, 2015. `https://www.rfc-editor.org/rfc/rfc7519`.

[7] Sheffer, Y.; Hardt, D.; Jones, M. *JSON Web Token Best Current Practices*, RFC 8725, 2020. `https://www.rfc-editor.org/rfc/rfc8725`.

[8] Rose, S.; Borchert, O.; Mitchell, S.; Connelly, S. *Zero Trust Architecture*, NIST SP 800-207, 2020. https://doi.org/10.6028/NIST.SP.800-207.

A Resumen de archivos del proyecto

Tabla 12: Ubicación de componentes relevantes.

Archivo / carpeta	Responsabilidad
auth/src/auth/auth.service.ts	Login, emisión de JWT, validación de sesión, logout y autorización.
auth/src/auth/roles.guard.ts	Comprobación de roles en operaciones administrativas.
auth/src/migrations/	Migración inicial versionada de las tablas y restricciones de AUTH.
auth/src/users/	Modelo, servicios, DTO y endpoints de usuarios.
auth/src/roles/	Gestión y persistencia de roles.
auth/src/user-roles/	Relaciones N:M y restricción de unicidad.
stego/src/steganography/subject.guard.ts	Validación local del Bearer JWT.
stego/src/steganography/stego.service.ts	Consulta AUTH, detector LSB y SQLite.
stego/src/steganography/stego.controller.ts	Recepción multipart y consulta de análisis.
scripts/	Configuración de demostración y pruebas repetibles.
samples/	Imágenes originales y modificadas.
openapi/*.openapi.yaml	Contratos REST incluidos con el informe.

B Lista de comprobación para la sustentación

1. Iniciar la infraestructura y verificar AUTH y STEGO como APIs separadas.
2. Crear o visualizar un usuario con dos roles y un rol asignado a dos usuarios.
3. Realizar login, inspeccionar el JWT y confirmar que no incluye permisos como fuente de autoridad.
4. Analizar una muestra válida con ADMIN o ANALYST; repetir con USER y comprobar HTTP 403.
5. Repetir sin JWT o con token alterado y comprobar HTTP 401.
6. Revocar ANALYST y repetir con el mismo JWT para obtener HTTP 403.
7. Interrumpir temporalmente AUTH y verificar HTTP 503 en STEGO sin procesamiento.
8. Comparar la imagen de referencia con una carga LSB y explicar las métricas, falsos positivos y falsos negativos.
9. Consultar SQLite, el recurso protegido y los logs de auditoría de ambos servicios.